



2016 中国互联网安全大会
China Internet Security Conference

协同联动 共建安全+命运共同体

BDSA大数据安全探讨 PPTD\UEBA\UCS技术

刘霖

北京天空卫士网络安全技术有限公司
创始人 CEO

TRGET和索尼攻击事件证明了，老旧的信息安全观念是不能适应全球移动互联网化的今天



中国互联网安全大会



360互联网安全中心

HVAC (空调供应系统) 承包商的计算机
1 安装恶意软件窃取凭证

2 利用窃取的凭证建立连接

Web应用程序承包商

3 开发Web应用程序漏洞

搜索相关的传播目标

窃取域管理员访问令牌
4 Web应用程序服务器

5 利用窃取的令牌创建新的域管理员账号

使用新的域管理员凭证进入相关计算机

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

23

24

25

26

27

28

29

30

31

32

33

34

35

36

37

38

39

40

41

42

43

44

45

46

47

48

49

50

51

52

53

54

55

56

57

58

59

60

61

62

63

64

65

66

67

68

69

70

71

72

73

74

75

76

77

78

79

80

81

82

83

84

85

86

87

88

89

90

91

92

93

94

95

96

97

98

99

100

101

102

103

104

105

106

107

108

109

110

111

112

113

114

115

116

117

118

119

120

121

122

123

124

125

126

127

128

129

130

131

132

133

134

135

136

137

138

139

140

141

142

143

144

145

146

147

148

149

150

151

152

153

154

155

156

157

158

159

160

161

162

163

164

165

166

167

168

169

170

171

172

173

174

175

176

177

178

179

180

181

182

183

184

185

186

187

188

189

190

191

192

193

194

195

196

197

198

199

200

201

202

203

204

205

206

207

208

209

210

211

212

213

214

215

216

217

218

219

220

221

222

223

224

225

226

227

228

229

230

231

232

233

234

235

236

237

238

239

240

241

242

243

244

245

246

247

248

249

250

251

252

253

254

255

256

257

258

259

260

261

262

263

264

265

266

267

268

269

270

271

272

273

274

275

276

277

278

279

280

281

282

283

284

285

286

287

288

289

290

291

292

293

294

295

296

297

298

299

300

301

302

303

304

305

306

307

308

309

310

311

312

313

314

315

316

317

318

319

320

321

花了60亿美金还不能安全的安全网络，加了10个亿美金的新盖子



中国互联网安全大会

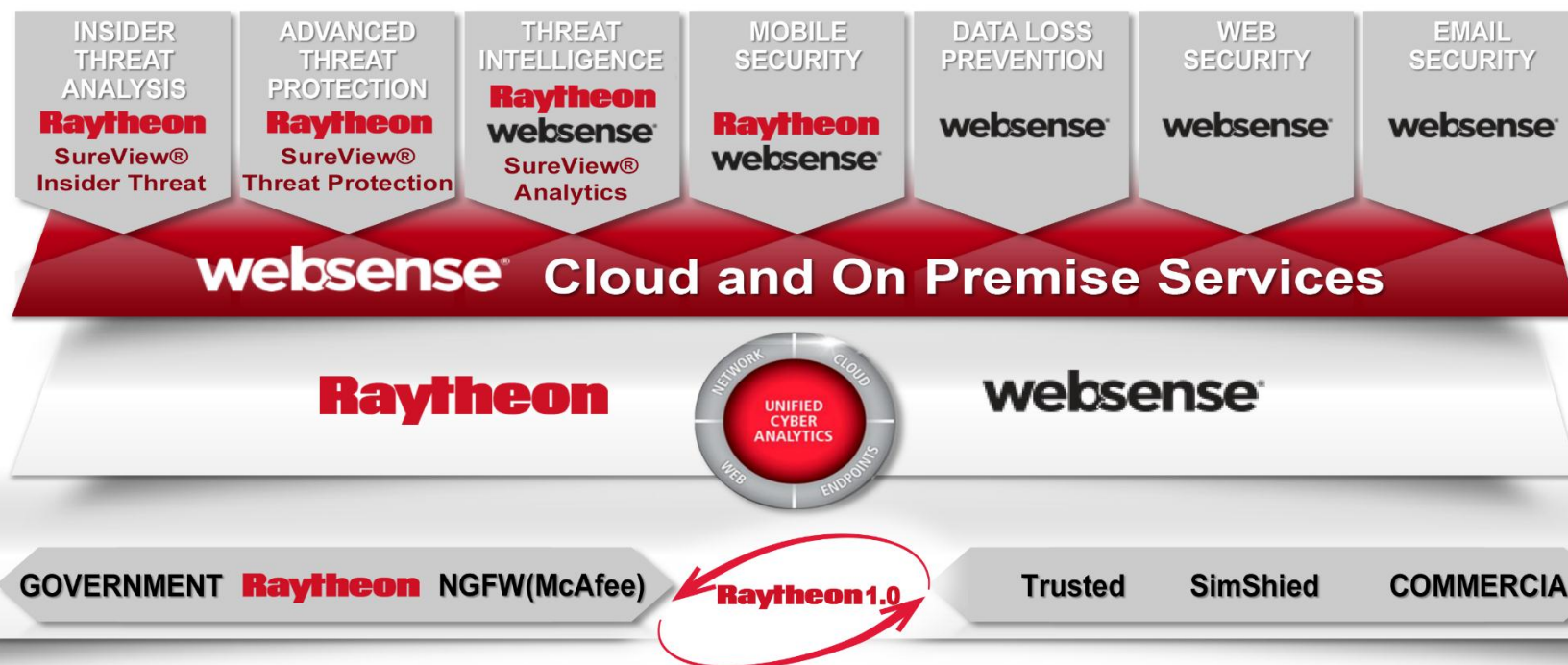


360互联网安全中心

Raytheon

Significant Synergies

PRODUCT AND CAPABILITY SYNERGIES



**Raytheon to leverage Websense's established commercial market presence;
Websense to leverage Raytheon's established government market presence**

世界上没有真正的内网，只有一张互联网，没有绝对的内网安全

以全球最大的军事内网-美军的JWICS网为例

2015年9月29日，美国国防部副部长罗伯特·沃克（Robert Work）在参议院军事委员会听证会上称：“我们防御（网络）攻击的能力尚未达到要求，”美国军队需增强防御电脑网络攻击的能力。

1、无法处理内网无边界情况时的军事安全问题。2011年11月，美国在阿富汗和其它区域执行飞行任务的



将SIPRNet和JWICS网内数据库内的大量资料刻录拷贝交给维基解密包括25万笔的美国外交电报和被称为伊拉克与阿富汗战争日志的50万笔陆军报告文件。借着维基解密及其合作伙伴于2010年4月至11月间一系列的资讯公开，此事件成为了有史以来最大的军事泄密案。

美国国会认为的美军只达到了最低安全标准，美军信息网络存在相当程度的数据泄漏风险（见美国众议院军事委员会 2015年1月通过GAO办公室对DOD的专项评估）。



中国互联网安全大会



360互联网安全中心

目录

- 概述
- 人员 (P: PEOPLE)
- 过程 (P: PROCESS)
- 技术 (T: TECHNOLOGY)
- 数据 (D: DATA)
- 小结

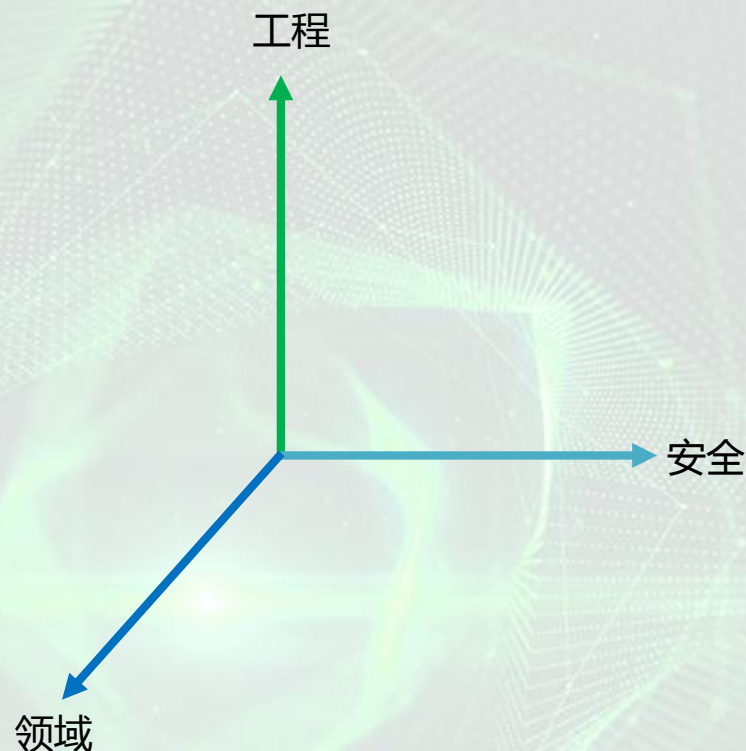
对于企业信息安全，若想得到结构性的保障就需要有一个系统性信息安全支撑体系。无论这个体系采用什么样的参考框架，都需要考虑四个关键的构成要素，即过程、人员、技术和数据（PPTD），其中：

- 过程是组织的系统性能力；
- 人员是过程执行的资源；
- 技术是过程有效性的支撑；
- 数据是过程执行的驱动。



信息安全高层专业人员知识结构包安全专业、业务领域和项目工程三个维度：

- 安全专业，安全专业知识包括数据安全技术、网络安全技术、应用安全技术等等。安全人员需要在安全专业领域所有专长并对整体有所了解。
- 业务领域，业务领域包括金融领域、能源领域、电子商务领域等等。企业安全是业务驱动的，对保护对象即相关业务领域理解的越透彻，安全措施就越能到位。
- 安全工程：安全工程包括信息安全风险管理、安全运行管理、安全项目实施管理等。安全工程知识是安全技术业务领域有效运用的基础。



人员：组织

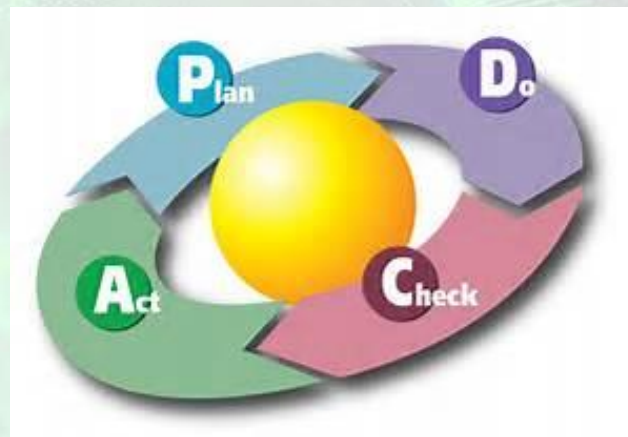
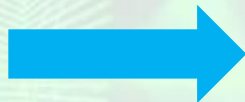


中国互联网安全大会



360互联网安全中心

企业信息安全组织包括三个层次：安全运行、安全运行管理和安全政策和策略确定。企业安全组织构成的基本逻辑是职责明确、统一指挥、有效协同。安全组织需要面向业务和安全管理确定可度量的指标，如MTTD、MTTR等。



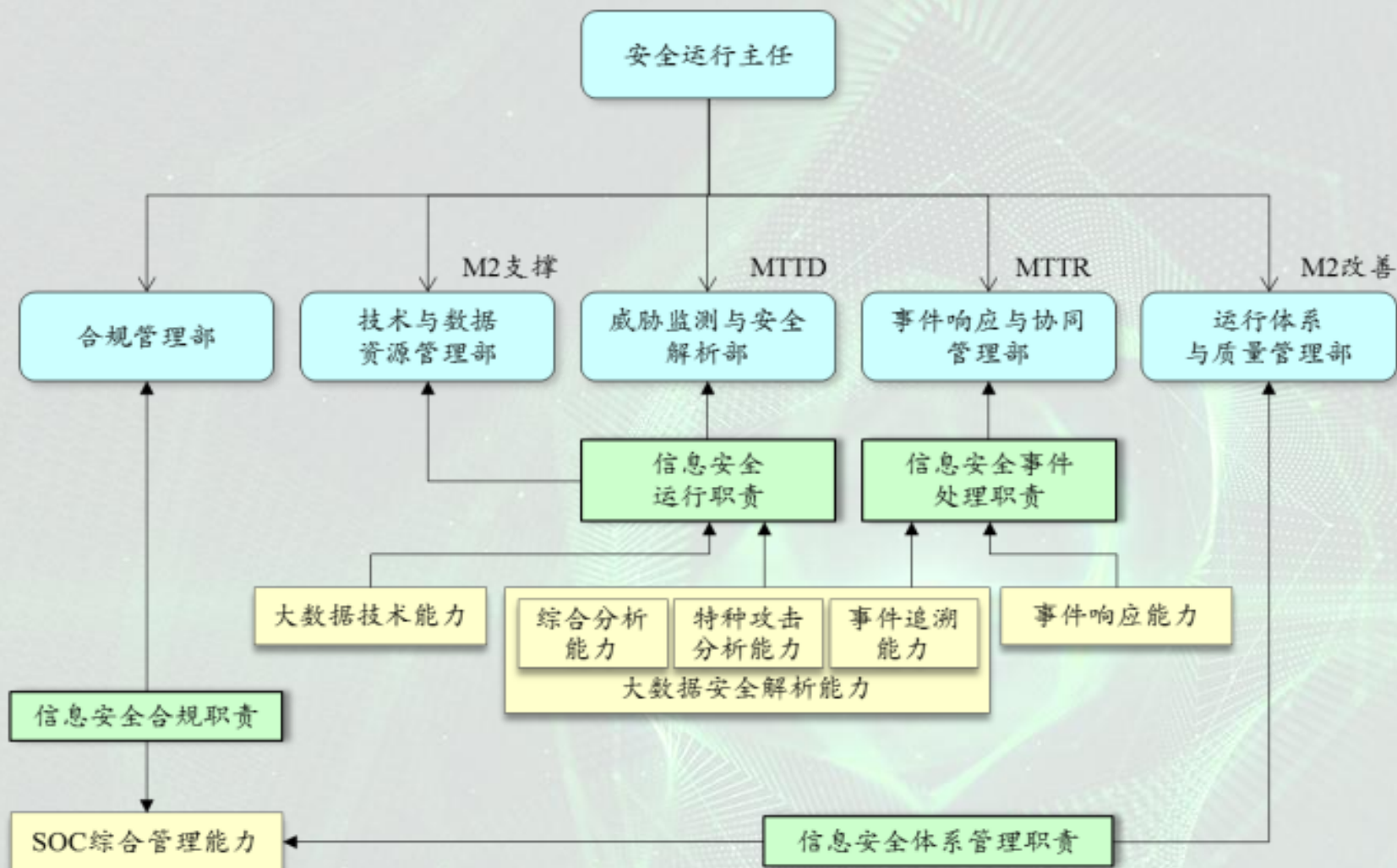
安全运行组织技能与能力需求（示例）



中国网络安全大会

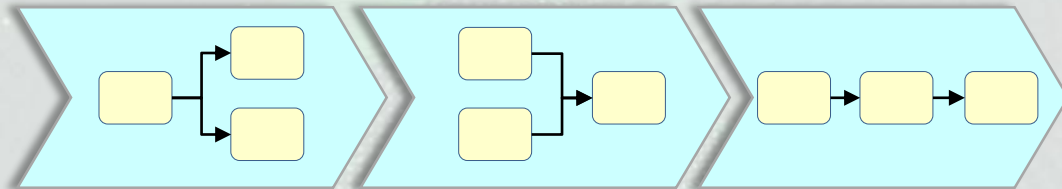


360互联网安全中心

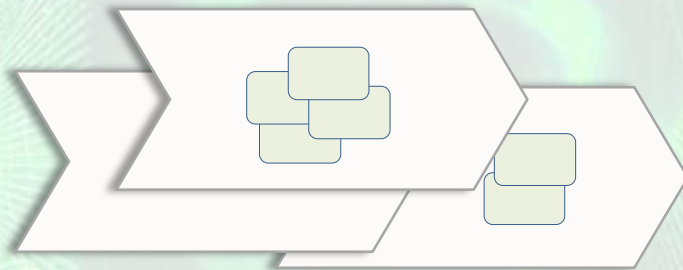


过程：“好”的安全过程与“坏”的安全过程

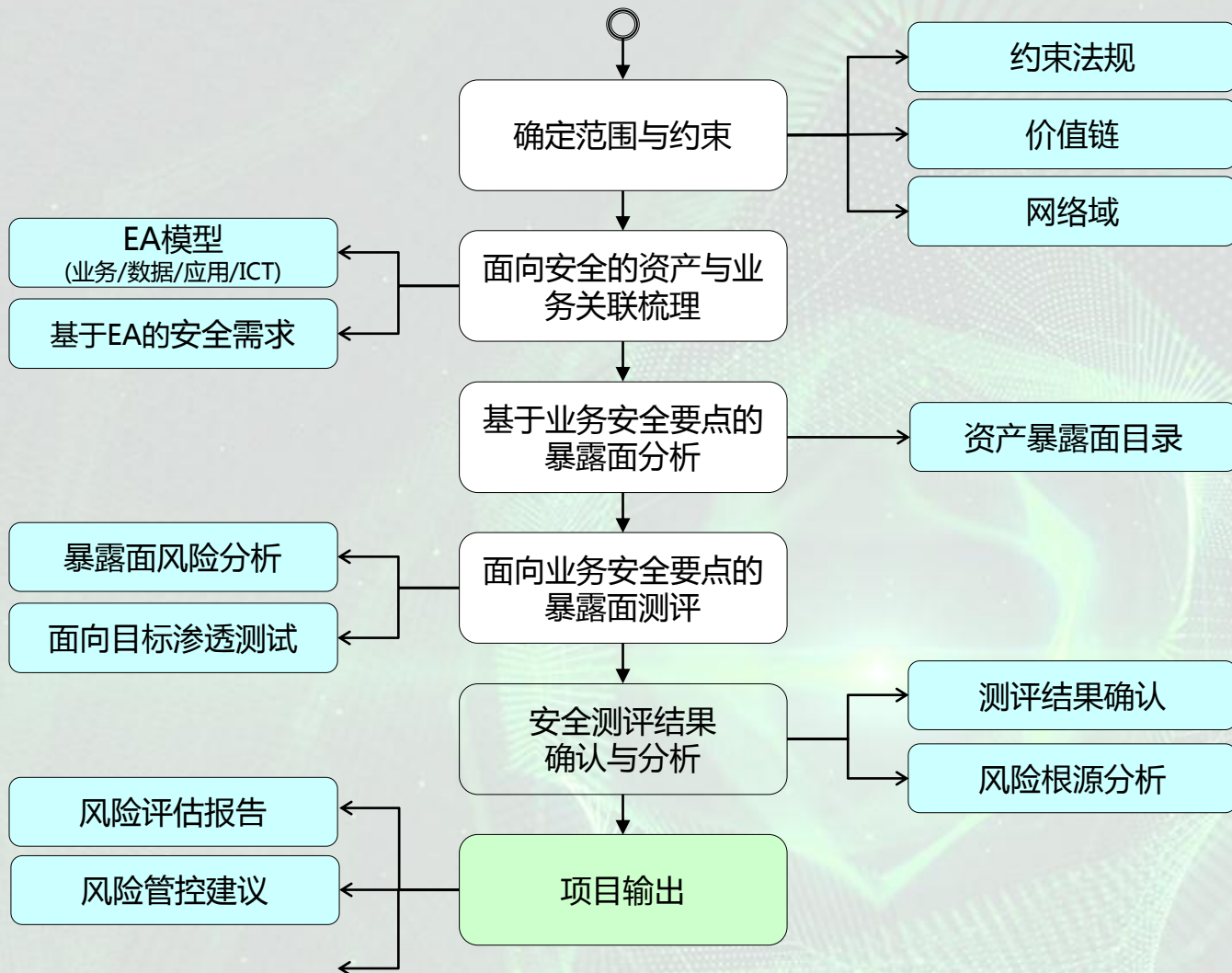
“好”的安全过程定义清晰、充分，能够重复使用，过程执行的结果质量可以预期。例如每次安全风险评估的结果可信度是一致的。



“坏”的安全过程定义混乱或根本没有定义，每次执行情况因人而异，执行过程基本是“黑箱”，执行结果质量起伏很大。例如按这样过程进行的安全风险评估结果难以确信。



业务风险评估过程（示例）



企业信息安全技术控制框架

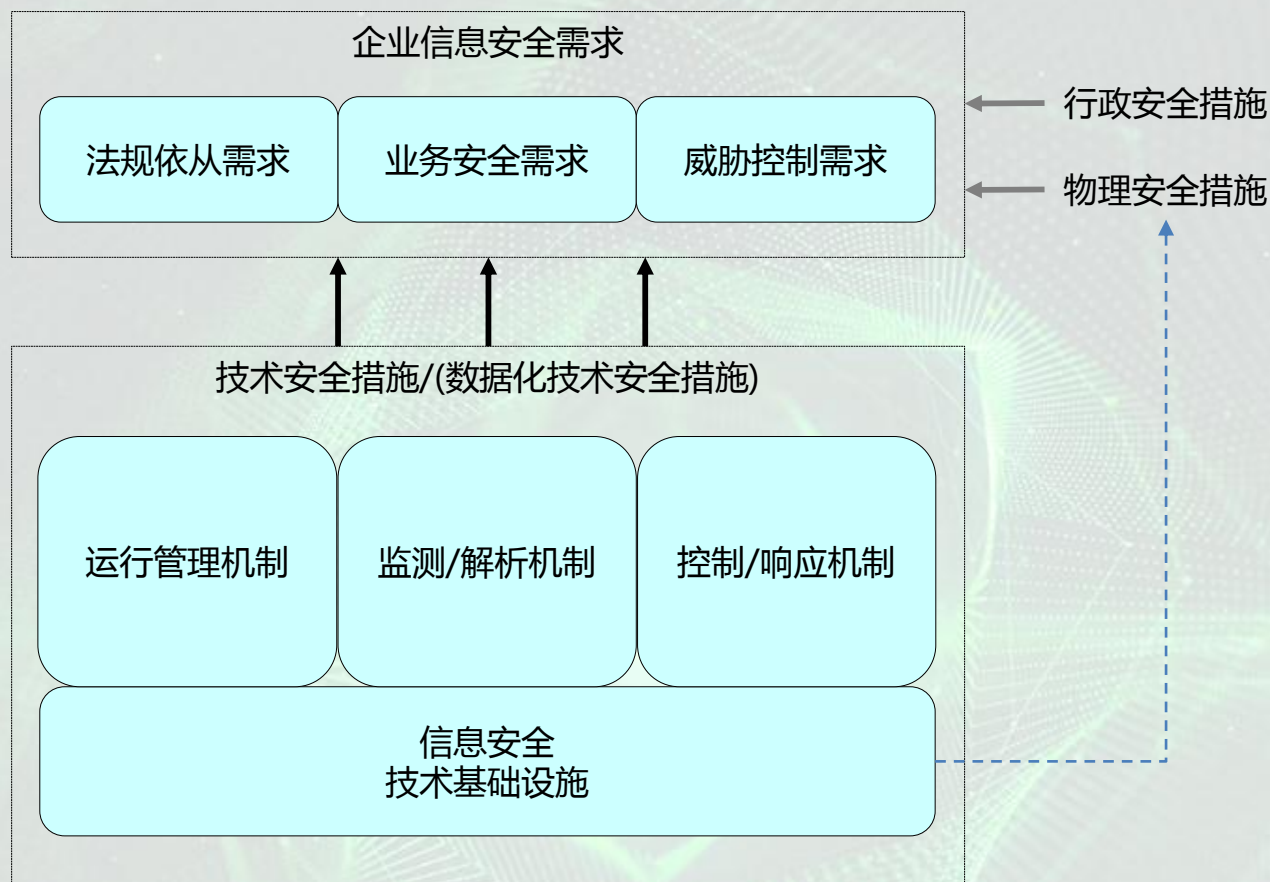


中国互联网安全大会



360互联网安全中心

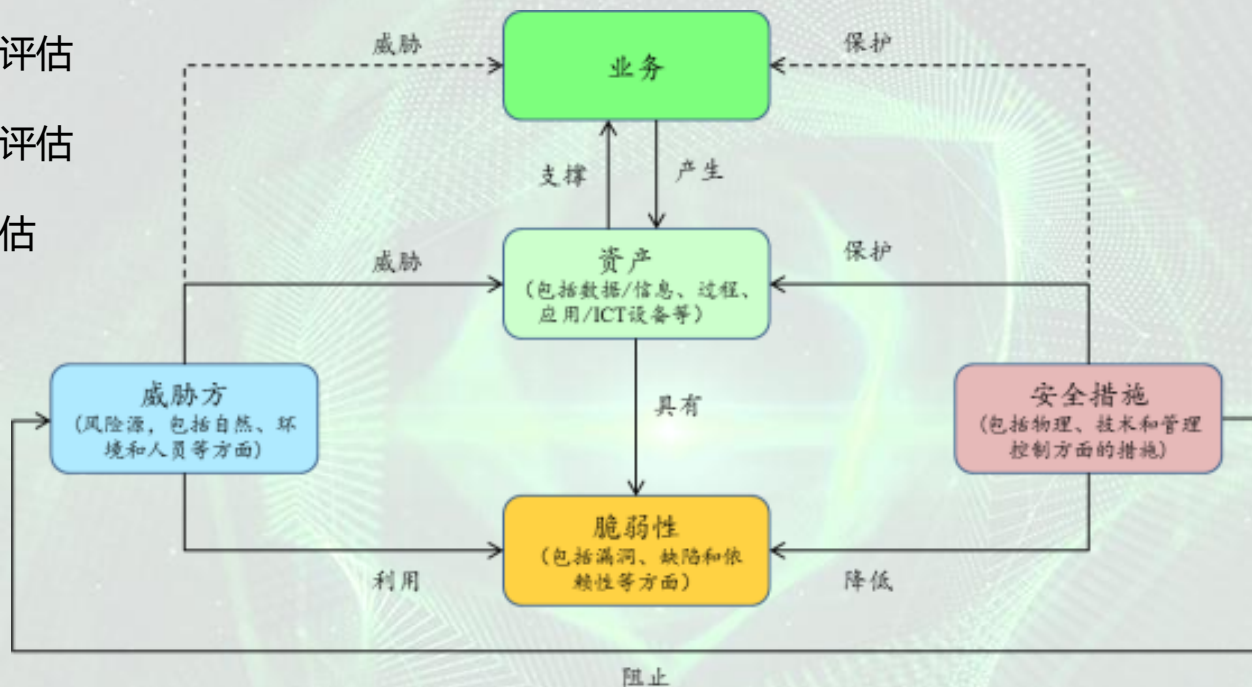
技术安全措施是满足企业信息安全需求的三类安全措施之一，也是其中最重要、最复杂的，因此需要通过架构的设计来保证技术控制之间的协同以及与其它安全控制的协同。



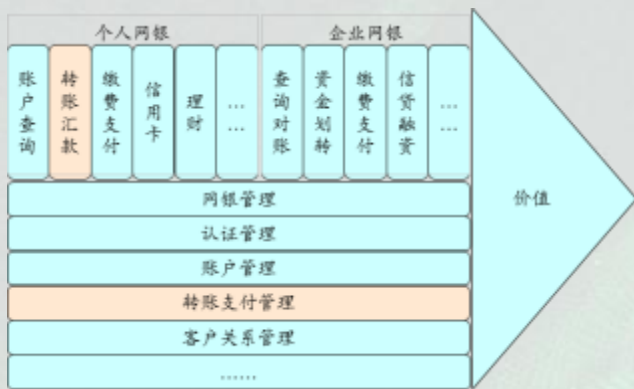
技术：有效性评估策略

风险的核心是围绕着业务支撑或业务产生的资产，并取决于资产自身的脆弱性和已采取的安全措施，因此安全技术有效性评估策略包括：

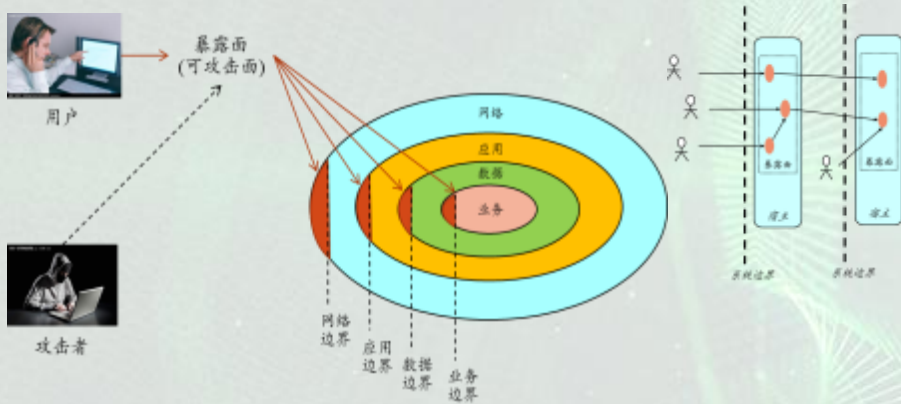
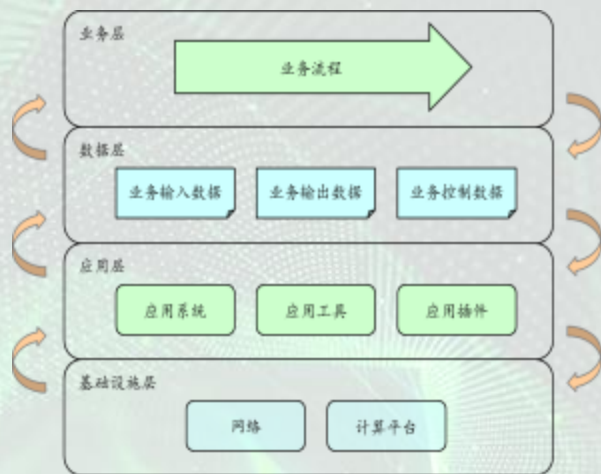
- 面向业务/业务资产的有效性评估
- 面向威胁方的有效性评估
- 面向脆弱性的有效性评估
- 综合加权的有效性评估



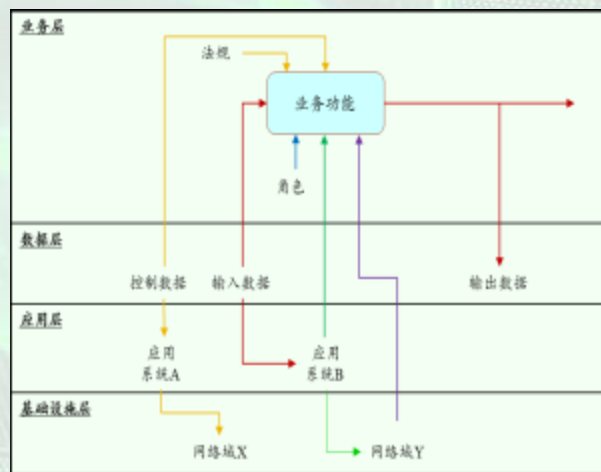
基于价值链的范围确定



基于EA的安全需求分析

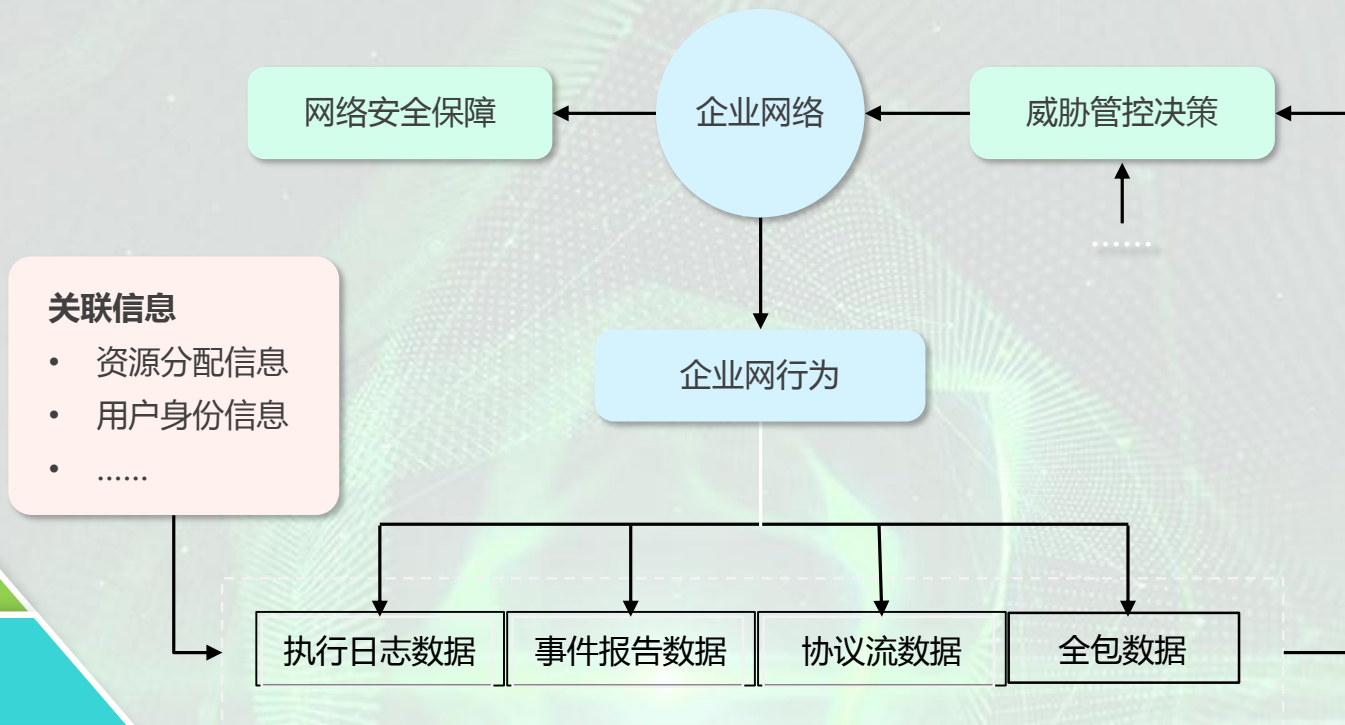
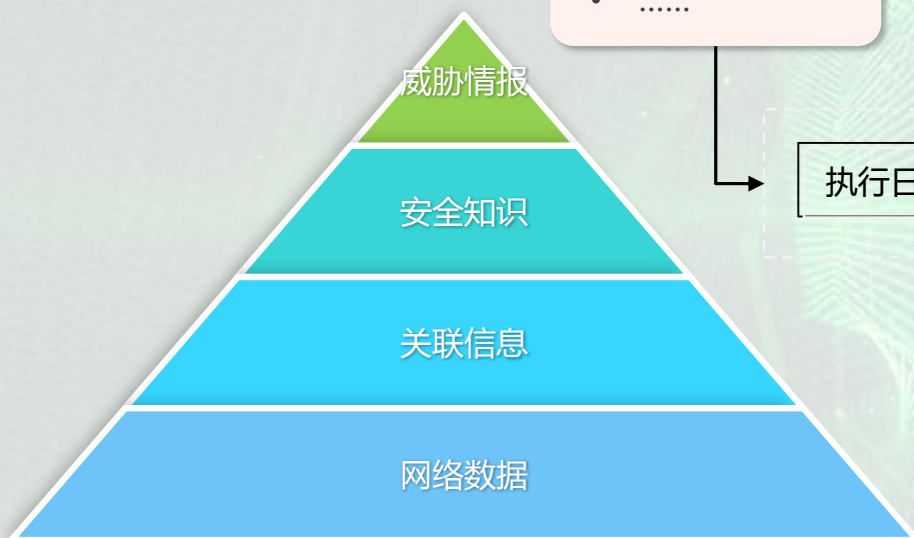


面向攻击语境的威胁评估



数据：行为的映射（安全的 / 不安全的）——需要智能内容安全技术支撑

数据用于安全是信息安全控制的一个新维度 (BDSA : Big Data Security Analytics), 首先网络空间的数据能够真实地反映网络主体的行为以及行为后面的模式, 其次, 大数据技术的发展提供了可能。



BDSA不仅仅是大数据, 而是以大数据为核心的数据全谱, 其中包括解读大数据的关联信息, 支撑大数据应用的安全知识和威胁情报。

传统的攻击检测方法

传统的攻击是基于“句法（Syntactic-based）”的，也称是“基于规则（Rule-based）”的。基于“句法”或“基于规则”的方法往往使用单一性指标（Atomic indicator）来检测攻击。这样的指标容易收集（如Hash值或IP），但与此同时攻击者也很容易通过改变这些指标来有效地逃避检测。现代的攻击已快速发展为3M方式（Multi-phased, Multi-asset, Multi-day），并导致受害者的巨大损失。

新一代的攻击检测方法

新一代攻击检测需要新的模型下（如Kill chain），运用大数据集合并基于语义（semantic-based）或模式（pattern-based）对攻击进行检测。

新一代基于语义或模式对攻击检测方法是面向攻击者使用的工具、技战术和执行过程。识别这些内容并不容易，但对应攻击者而言也很难改变。

将大数据、语义模型和KC模型结合到一起，提供了有效检测出现代地攻击的潜能。

背景

2013年，RSA、EMC和NEU以EMC企业网环境为基础，联合进行了大数据安全解析实验，据称该实验在当时是实际环境下大数据安全解析的首例应用。实验环境为EMC真实环境，数据量平均每天14亿条日志，约1TB数据，解析数据超过6T。监测对象包括EMC所有活跃主机，工作日规模为27,000 ~ 35,000台，周末规模为9,000~10,100台主机。

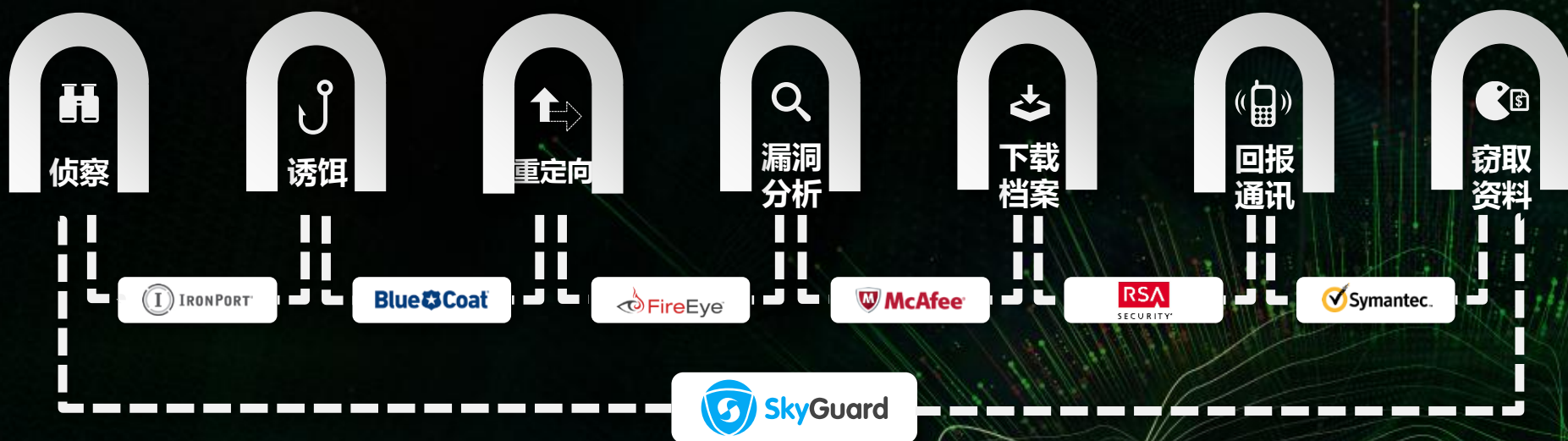
算法概要

由于缺乏异常行为数据，项目采用了非监督学习的聚类算法。采用PCA(Principal Component Analysis)方法消除特征间的依赖关系、降低计算维度，采用了改进的K-means算法，进行聚类。

两周解析结果(2013/4/22~2013/5/5)：

784个事件（平均每天56个）；
仅有8个事件与企业先进的安全设备识别的事件相同；
通过SOC对每个事件进行了复核：
25.25%是恶意软件相关事件
39.41%违规事件
35.33%未能识别原因

UCS统一内容安全技术 才能有效解决APT等新威胁



传统的技术必须升级到能够智能感知内容的新信息安全技术！

统一内容安全中心 Unified Content Security



SkyGuard Cloud



SecGator Security Engine



SecGator DLP IAS Engine

SWG

Web安全网关

针对高级威胁和数据窃取的最有效防护

SEG

邮件安全网关

针对混合攻击和定向攻击的最先进邮件防护

DLP

数据防泄漏

采用深层内容分析，对静态、传输中及使用中的数据进行分析、识别、监控、保护，拥有用户及目的地感知的特色功能

Cloud

接入安全云

对任意地点的 web 及邮件提供最佳防护，并且拥有最低的总体拥有成本和最轻松的部署

Mobile

移动安全

对移动数据特有的有效防护，针对窃取、遗失、app 及 web 威胁

UCS技术里为何要首推DLP产品？

1

DLP 是 APT 攻击最后一道防线

内部信息泄漏的最后一道防线

2

美国UCS产品的部分中国用户（2007-2014），超过3000家客户



使用各种云服务的企业员工 workflows 管理——云时代的云DLP

云DLP：满足中小企业，用很低的支出，保护自己的数据资产



UCS技术全貌 —— UCS技术不止是DLP

内部威胁分析/行为分析

高级威胁防护

威胁分析/态势感知

移动端安全

数据防泄漏

Web安全

邮件安全



SkyGuard

云和硬件方式提供服务

网络

云

统一网络分析

Web

终端

外部情报
威胁共享

智能
SOC 系统

传统网络
安全技术
数据

DLP 技术核心：数据识别 & 分类引擎

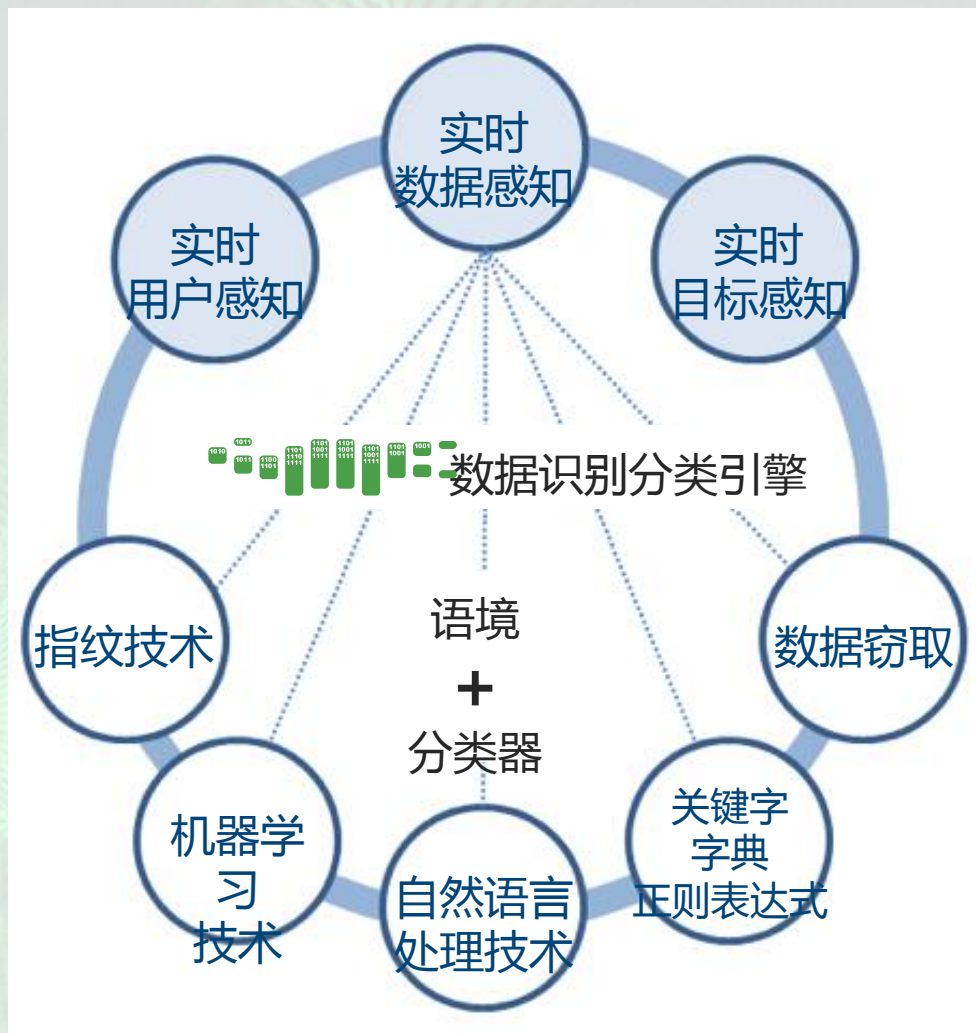


中国互联网安全大会



360互联网安全中心

SkyGuard 数据防泄漏使用上下文感知的方式对数据进行分类



SWG技术核心：实时威胁及内容分析



中国互联网安全大会



360互联网安全中心

- **实时威胁引擎**

安全、数据、内容

超过一万种分析

- **三种反恶意软件引擎**

商业反病毒引擎

启发式分析引擎

恶意PDF引擎

- **鱼叉式钓鱼攻击、信誉服务及Web链接防御**

- **复合评分模型**



综合评分 — 投票表决



中国互联网安全大会



360互联网安全中心

- 在检测复杂及未知威胁时，关联的综合评分正在变得更加重要

- 简单例子**

RTSC (实时安全分类)：未知的模糊处理

Reputation (信誉分析)：阈值以下

URL 类别：未分类

结果 = 可能的恶意站点

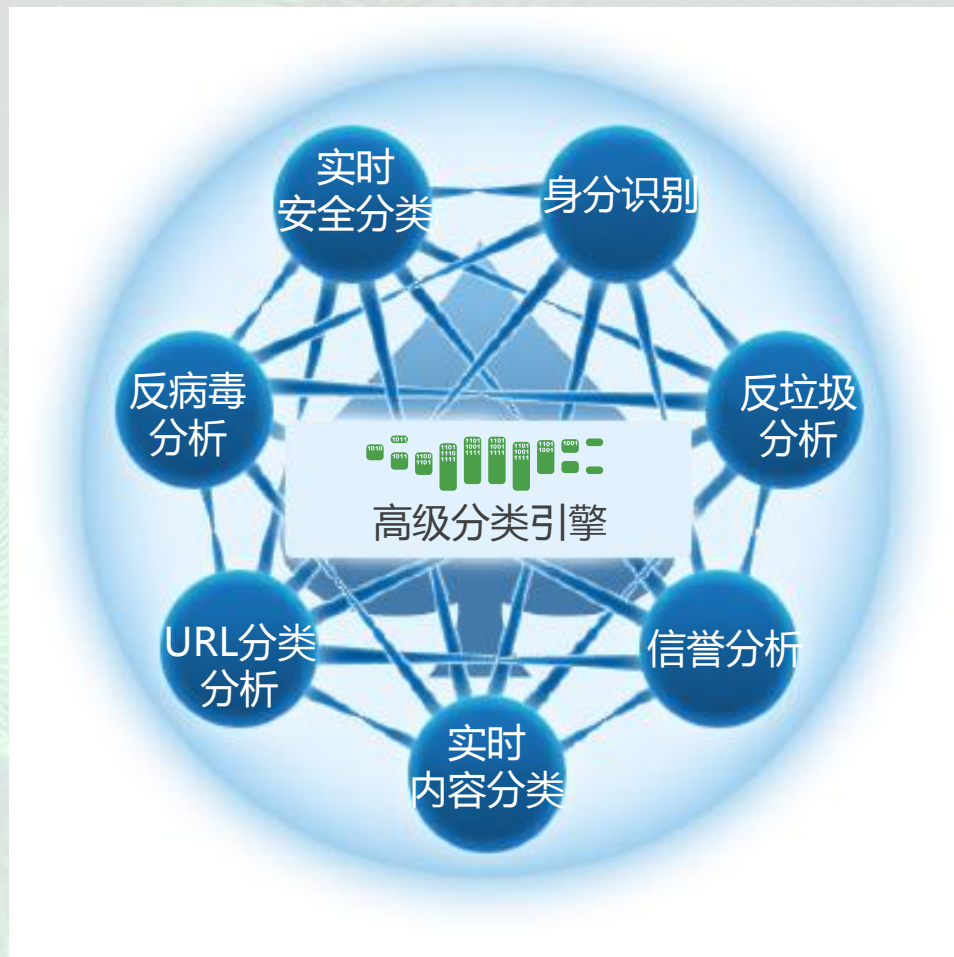
- 复杂例子**

URL 类别：动态DNS

Reputation (信誉分析)：阈值以下

PreciseID (身份证号)：未知加密

结果 = APT / 定向攻击



安全技术发展



安全鳄DLP 百万奖金、免费试用计划

智能安全咨询顾问——串行或旁路监控网络进出内容，告诉您的数据资产是否健康、安全



免费使用（时间一个月），插电即用，上网即行

免费获得天空卫士技术售后中心电话和远程7x24白金支持（时间一个月）

企业互联网使用人数在500人以上即可，人数多的单位从优。测试期间、发现产品质量问题给予奖励、发现重大问题最高可以奖励10万块！

联系邮件：dlppoc@skyguard.com.cn

联系人：赵欣 13520489019 或 光临我们本次大会的展台（B09-B12）

谢 谢



中国互联网安全大会



360互联网安全中心